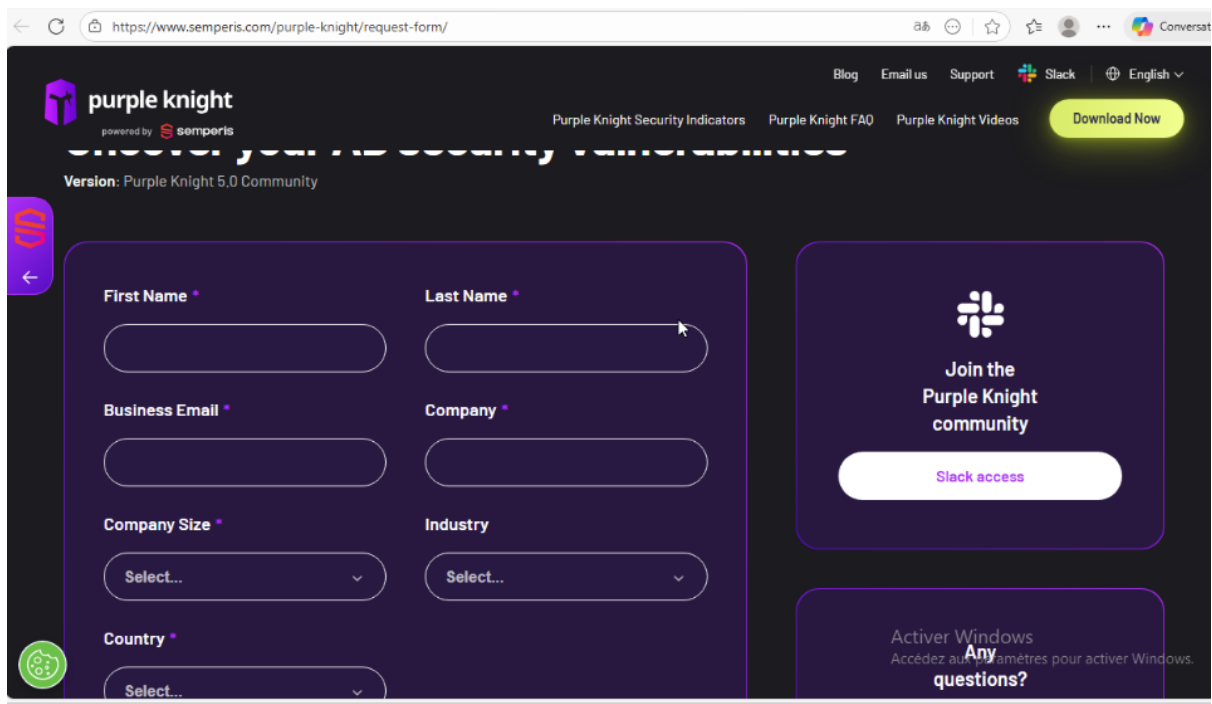


Audit de Sécurité Active Directory avec Purple Knight

1. Introduction à l'outil

Purple Knight est un outil d'audit de sécurité développé par Semperis. Contrairement à un simple scanner de vulnérabilités, il se concentre sur les **Indicateurs d'Exposition (IoE)** et les **Indicateurs de Compromission (IoC)** spécifiques à l'Active Directory.

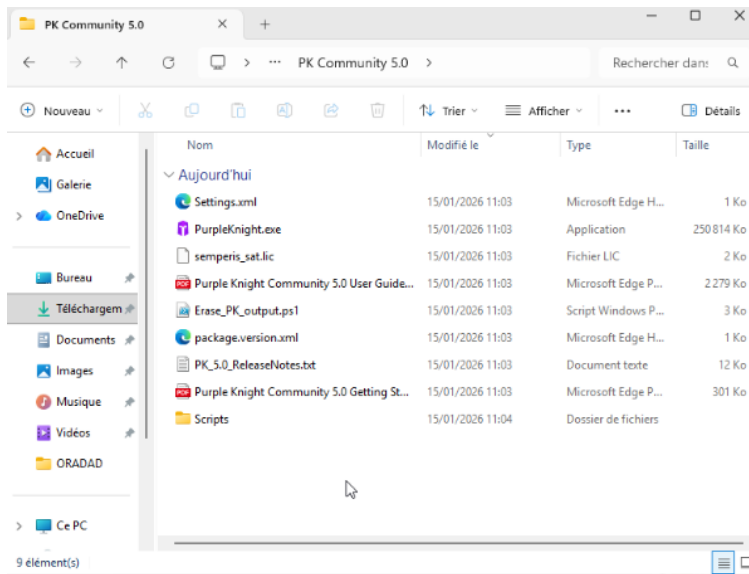


The screenshot shows the 'request-form/' page of the Purple Knight tool. The page has a dark theme with purple accents. At the top, there's a navigation bar with links for 'Blog', 'Email us', 'Support', 'Slack', and 'English'. A 'Download Now' button is also present. The main content area features a form with fields for 'First Name', 'Last Name', 'Business Email', 'Company', 'Company Size', 'Industry', and 'Country'. To the right of the form, there's a section titled 'Join the Purple Knight community' with a 'Slack access' button. At the bottom right, there's a small section for 'Activater Windows' with a link to 'Any questions?'. The page is powered by Semperis, and the version is noted as 'Purple Knight 5.0 Community'.

2. Phase de Lancement et Configuration

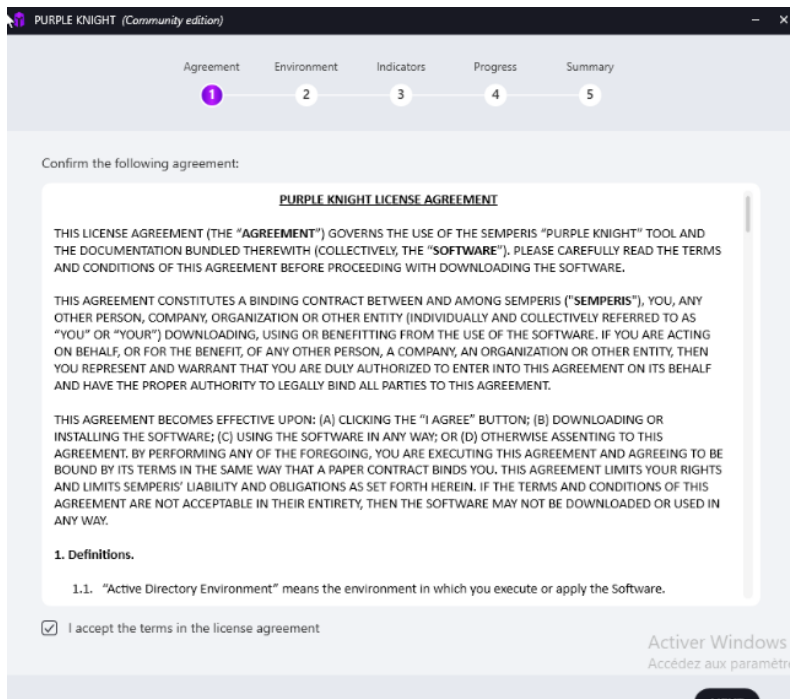
A. Exécution du programme

- **Action** : Lancement de PurpleKnight.exe.
- **Commentaire** : L'outil s'exécute sans installation. Il nécessite d'être lancé depuis une machine membre du domaine avec un compte disposant de droits de lecture sur l'ensemble de l'annuaire (généralement un administrateur du domaine pour un scan complet).



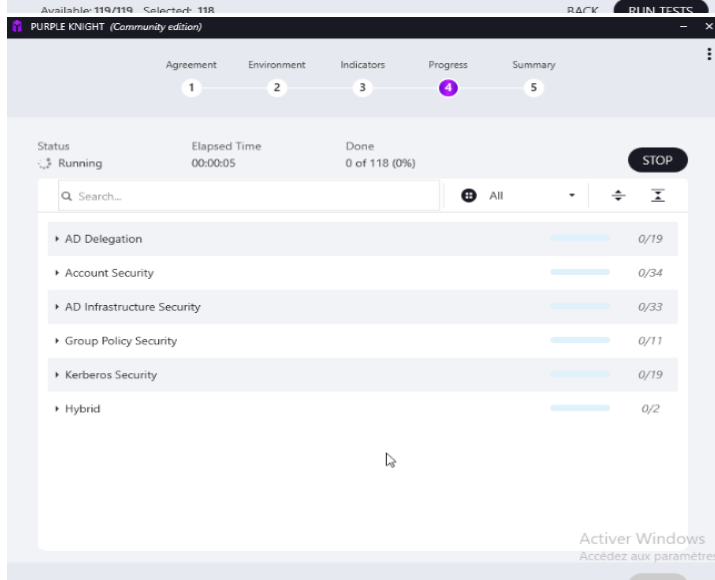
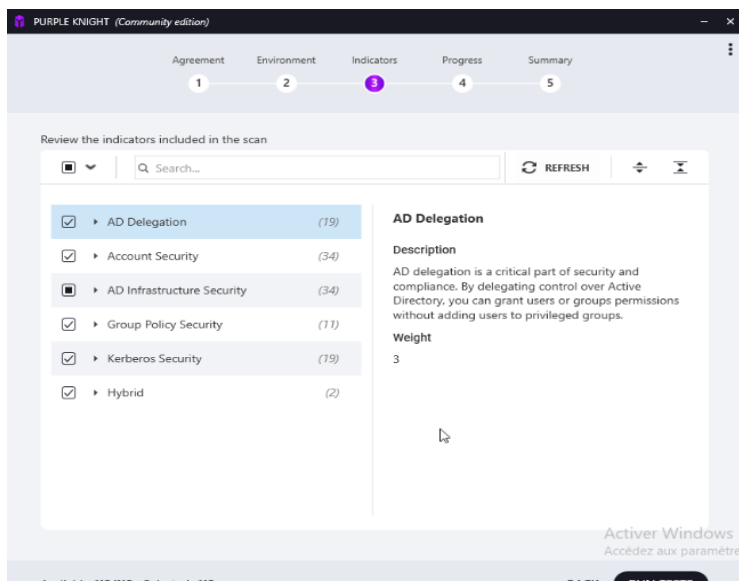
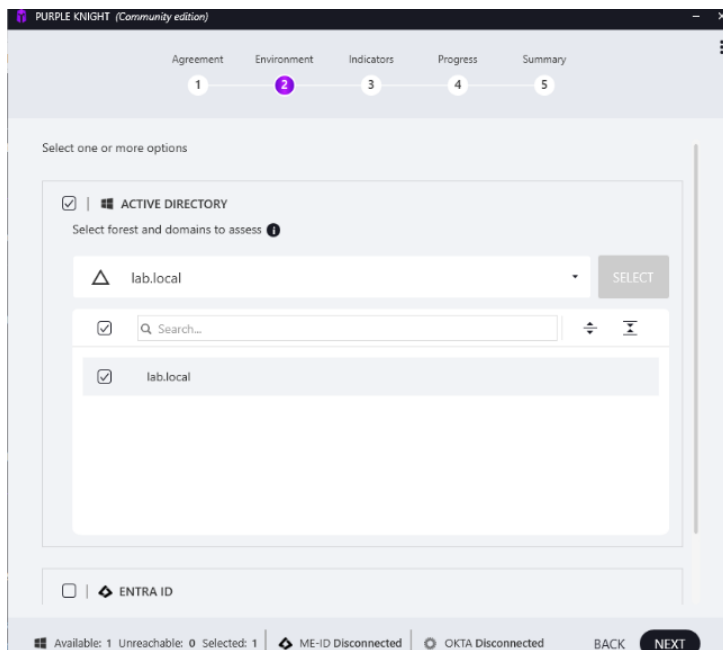
B. Acceptation des termes et conditions

- **Action** : Validation de la licence "Community Edition".
- **Commentaire** : Cette version est gratuite pour les audits ponctuels et permet d'accéder à plus de 100 indicateurs de sécurité mis à jour régulièrement.



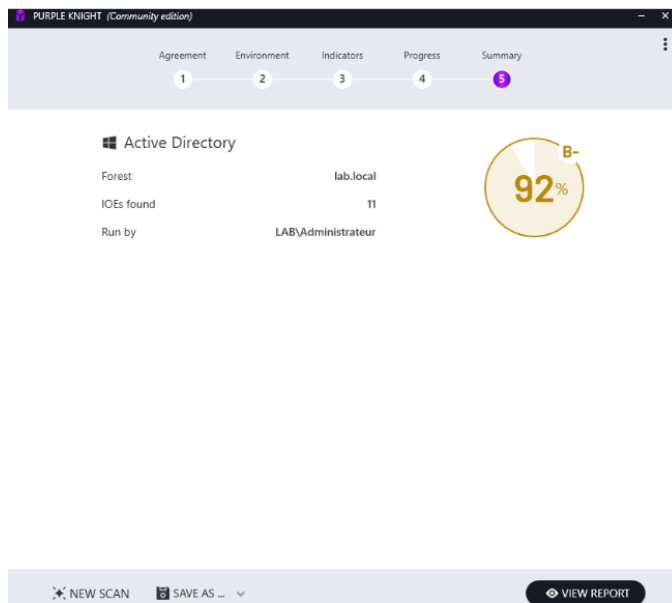
C. Sélection du périmètre

- **Action** : Choix du domaine lab.local.
- **Commentaire** : L'outil détecte automatiquement la forêt et le domaine actuels. On sélectionne ici l'Active Directory comme cible principale.



3. Analyse du Score Global

- **Score obtenu : 92% (Grade B-).**
- **Explication :** Ce score est une moyenne pondérée. Bien que le chiffre semble élevé, la présence de vulnérabilités dans la catégorie "Critical" (Sévérité Critique) signifie que le domaine peut être compromis malgré une bonne note globale.



ACTIVE DIRECTORY

Forest	lab.local
No. of Domains	1
Duration	00:00:56
Run by	LAB\Administrate...

Indicators

Evaluated	115
Not selected	1
IOEs found	11
Passed	104
Failed to run	0
Not Relevant	3
Canceled	0

CRITICAL IOEs FOUND

Print spooler service is enabled on a DC

This indicator checks for Domain Controllers running the print spooler service...

[Read More](#)

Privileged Users with Weak Password Policy

This indicator looks for privileged users in each domain that don't have a strong password policy enforced, according to ...

[Read More](#)

ADDITIONAL IOEs FOUND

NAME	PLATFORM	SEVERITY LEVEL	ACTION
• LDAP signing is not required on Domain Controllers	AD	High	Read More
• RC4 or DES encryption type are supported by Domain Controllers	AD	High	Read More
• Built-in domain Administrator account used within the last two weeks	AD	Medium	Read More
• Changes to Pre-Windows 2000 Compatible Access Group membership	AD	Medium	Read More
• gMSA not in use	AD	Medium	Read More
• Recent privileged account creation activity	AD	Low	Read More
• Unprivileged users can add computer accounts to the domain	AD	Low	Read More
• Protected Users group not in use	AD	Info	Read More
• Users with Password Never Expires flag set	AD	Info	Read More

Analyse des Indicateurs d'Exposition (IoE)

Risques de Sévérité Haute (Critiques)

- **Signature LDAP non requise sur les DC (+ High)** : Le serveur n'exige pas que les échanges LDAP soient signés. Un attaquant positionné sur le réseau peut intercepter ces communications (Man-in-the-Middle) pour voler des identifiants ou injecter des modifications malveillantes dans l'annuaire.
- **Support des chiffrements RC4 ou DES (+ High)** : Les types de chiffrement obsolètes RC4 et DES sont encore supportés par les contrôleurs de domaine. Ces algorithmes sont considérés comme faibles et vulnérables à des attaques de décryptage rapide par rapport aux standards AES modernes.

Risques de Sévérité Moyenne

- **Utilisation du compte Administrateur intégré (+ Medium)** : Le compte "Administrateur" natif du domaine a été utilisé au cours des deux dernières semaines. L'utilisation régulière de ce compte partagé augmente les risques de compromission ; la recommandation est d'utiliser des comptes nominatifs avec des privilèges moindres pour l'administration quotidienne.
- **gMSA non utilisé (+ Medium)** : l'infrastructure n'exploite pas les comptes de service gérés par le groupe (group Managed Service Accounts). Sans gMSA, les services

utilisent souvent des mots de passe statiques qui ne sont jamais renouvelés, facilitant leur compromission par des attaques de type "Kerberoasting".

- **Changements dans le groupe "Pre-Windows 2000 Compatible Access" (+ Medium)** : Des modifications ont été détectées dans l'appartenance à ce groupe de compatibilité. Un groupe trop permissif peut permettre à des utilisateurs authentifiés de lire des informations sensibles sur d'autres comptes de l'annuaire.

Risques de Sévérité Faible & Infos

- **Création de comptes ordinateurs par des non-privilegiés (+ Low)** : Des utilisateurs non privilégiés conservent le droit d'ajouter des machines au domaine. Cela représente un vecteur classique pour introduire des systèmes non maîtrisés ou des outils d'attaque au sein du réseau.
- **Activité récente de création de comptes privilégiés (+ Low)** : Des comptes avec des hauts privilèges ont été créés récemment. Ce point nécessite une vérification pour s'assurer que ces créations sont légitimes et non le signe d'une tentative de persistance d'un attaquant.
- **Groupe "Protected Users" non utilisé (Info)** : Ce groupe de sécurité, qui impose des restrictions strictes (désactivation de NTLM, limitation de la délégation, etc.), n'est pas utilisé pour les comptes sensibles. Son activation est une étape clé pour un durcissement (hardening) moderne de l'AD.
- **Comptes avec le flag "Password Never Expires" (Info)** : Des utilisateurs possèdent des mots de passe qui n'expirent jamais, ce qui contrevient aux politiques de sécurité standards et augmente le risque en cas de fuite d'identifiants.

4. Analyse des Vulnérabilités Critiques (Les "Critiques")



SECURITY INDICATOR
gMSA not in use

IOE Found 94%

SEVERITY
Medium

WEIGHT
4

Security Frameworks
MITRE ATT&CK
• Credential Access

Description
This indicator checks if there are enabled group Managed Service Account (gMSA) objects in the domain.

Likelihood of Compromise
The group Managed Service Account (gMSA) feature in Windows Server 2016 allows automatic rotation of passwords for service accounts, making them much more difficult for attackers to compromise. The feature should be used whenever possible for service accounts.

References
[Get started with Group Managed Service Accounts](#)

Result
Found 1 domains with no gMSA objects enabled.

DomainName	Ignored
lab.local	False

Showing 1 of 1

Remediation Steps
Group Managed Service Accounts should be used to protect service accounts. See description for more information.

gMSA not in use (Sévérité Moyenne)

Cet indicateur vérifie s'il existe des objets de type "Group Managed Service Account" (gMSA) actifs dans le domaine.

- **Explication (Cause)** : L'audit révèle qu'aucun objet **gMSA** (Group Managed Service Accounts) n'est activé dans le domaine lab.local. Actuellement, l'infrastructure repose sur des comptes utilisateurs classiques ou des comptes de service standards pour le fonctionnement des applications réseau. Contrairement aux comptes gMSA, ces comptes traditionnels imposent une gestion manuelle des mots de passe, ce qui mène souvent à l'utilisation de secrets statiques n'expirant jamais pour éviter toute interruption de service.
- **Conséquence (Risque)** : Cette situation expose directement les services à des attaques de vol d'identifiants (**Credential Access**). Les comptes de service classiques constituent des cibles prioritaires car les mots de passe sont plus simples à compromettre, soit par force brute, soit par des attaques de type "**Kerberoasting**". L'utilisation de gMSA permettrait d'éliminer ce risque puisque l'Active Directory assurerait lui-même une rotation automatique et complexe des mots de passe, les rendant pratiquement impossibles à voler ou à craquer.

 SECURITY INDICATOR

Unprivileged users can add computer accounts to the domain

IOE Found

96%

SEVERITY

Low

WEIGHT

3

Security Frameworks

MITRE ATT&CK

- Credential Access
- Lateral Movement

ANSSI

- vuln4_user_accounts_machineaccountquota

Description

This indicator checks for an AD configuration that allows unprivileged domain members to add computer accounts to the domain. By default, members of the Authenticated Users group can add up to 10 machine accounts to a domain. If the ms-DS-MachineAccountQuota attribute on the domain naming context head is not set to 0, regular users have this ability. The ability to do this confers certain rights on those created machine accounts that can be abused by a variety of Kerberos-based attacks. (Note: This configuration may be enabled but be already mitigated by GPO settings (User Right: "Add workstations to domain" configured with only high-privileged group(s)/account(s)) linked to Domain Controllers OU that are not checked by this indicator.

Likelihood of Compromise

The ability to add computer accounts to a domain without restrictions or monitoring present opportunities for attackers to add their own accounts or take advantage of uncontrolled computers with vulnerabilities, thereby extending their reach and entrenching themselves in the environment.

References

[Unrestricted domain join \(ANSSI\)](#)

Result

Found 1 domains in which regular users can add computer accounts.

MachineAccountQuota	DistinguishedName	Ignored
10	DC=lab.DC=local	False

Showing 1 of 1

Remediation Steps

Set the ms-DS-MachineAccountQuota attribute on the domain NC head to 0 to disable regular users' ability to add computer accounts.

Unprivileged users can add computer accounts to the domain (Sévérité Faible)

Cet indicateur vérifie la configuration de l'Active Directory qui permet aux membres non privilégiés du domaine d'y joindre des comptes ordinateurs.

- **Explication (Cause) :** Par défaut, dans un environnement Active Directory, l'attribut ms-DS-MachineAccountQuota est configuré sur la valeur **10**. Cela signifie que n'importe quel membre du groupe "**Utilisateurs authentifiés**" peut ajouter jusqu'à 10 nouveaux ordinateurs au domaine lab.local sans détenir de droits d'administrateur. L'audit confirme que cette valeur par défaut est toujours active au sein de l'infrastructure.
- **Conséquence (Risque) :** Cette capacité offre des opportunités pour un attaquant de créer des machines au sein du réseau sans restriction ni surveillance. Selon le framework **MITRE ATT&CK**, cela facilite l'accès aux identifiants (**Credential Access**) et le déplacement latéral (**Lateral Movement**). En introduisant des ordinateurs non contrôlés, un attaquant peut étendre sa portée, abuser de diverses attaques basées sur **Kerberos** et s'ancrer durablement dans l'environnement.

SECURITY INDICATOR
Built-in domain Administrator account used within the last two weeks
IOE Found
91%

SEVERITY
Medium

WEIGHT
5

Security Frameworks
MITRE ATT&CK

- Credential Access

MITRE D3FEND

- Detect - Credential Compromise Scope Analysis
- Harden - Strong Password Policy

Description
The Domain Administrator account should only be used for initial build activities and, when necessary, disaster recovery. This indicator checks to see if the lastLogonTimestamp for the built-in Domain Administrator account has been updated within the last two weeks. If so, it could indicate that the user has been compromised.

Likelihood of Compromise
If best practices are followed and domain Admin is not used, this would indicate a compromise. Ensure any logins to the built-in Domain Administrator account are legitimate and accounted for. If not accounted for, a breach is likely and should be investigated.

Result
Found 1 domains in which the built-in administrator was used recently.

EventTimestamp	DistinguishedName	Ignored
20/01/2026 09:31:36	CN=Administrateur,CN=Users,DC=lab,DC=local	False

Showing 1 of 1

Remediation Steps
Ensure that the built-in domain Administrator account is not used regularly and has a complex password known only to highly privileged admins.

Built-in domain Administrator account used within the last two weeks (Sévérité Moyenne)

Cet indicateur vérifie si le compte "Administrateur" natif du domaine a été utilisé récemment pour s'authentifier.

- **Explication (Cause) :** L'audit détecte que l'attribut lastLogonTimestamp du compte administrateur intégré (SID se terminant par -500) a été mis à jour au cours des deux dernières semaines. Dans l'environnement lab.local, une connexion est enregistrée le **20/01/2026 à 09:31:36**. En temps normal, ce compte ne doit être sollicité que pour les activités initiales de construction du domaine ou pour une récupération après sinistre (*disaster recovery*). L'utilisation régulière indique

que les administrateurs ne se servent pas de comptes nominatifs personnels pour les tâches quotidiennes.

- **Conséquence (Risque) :** L'utilisation de ce compte pose un problème de traçabilité et de sécurité. Comme il s'agit d'un compte partagé disposant de privilèges totaux, il est impossible d'identifier avec certitude la personne physique ayant effectué une action. Selon les frameworks **MITRE ATT&CK** et **D3FEND**, cela facilite l'accès aux identifiants (**Credential Access**). Si ce compte n'est pas utilisé par un administrateur légitime, cela peut signifier que le domaine est compromis, ce compte étant une cible prioritaire pour obtenir un contrôle total et permanent sur l'annuaire.

 **SECURITY INDICATOR**
Recent privileged account creation activity

IOE Found 

SEVERITY

Low

WEIGHT

3

Security Frameworks

MITRE ATT&CK

- Persistence

MITRE D3FEND

- Detect - Domain Account Monitoring

Description

This indicator looks for any users or groups that were created within the last month. Privileged accounts and groups are defined by having their adminCount attribute set to 1.

Likelihood of Compromise

In most environments, creation of privileged accounts and groups is tightly controlled and audited. This indicator provides a fast method to create a list of new privileged accounts (where adminCount = 1) for investigation and review.

References

[audit-user-account-management of Microsoft](#)

Result

Found 2 objects that were created in the last 30 days and are members of a privileged group.

DistinguishedName	SamAccountName	EventTimestamp	Ignored
CN=Administrateur,CN=Users,DC=lab,DC=local	Administrateur	06/01/2026 16:13:12	False
CN=krbtgt,CN=Users,DC=lab,DC=local	krbtgt	06/01/2026 16:15:56	False

Showing 2 of 2

Remediation Steps

Review the list and verify that all privileged accounts and groups that were recently created are valid. Ideally, all privileged account creation goes through an approval-based workflow and gets periodic attestation.

Recent privileged account creation activity (Sévérité Faible)

Cet indicateur surveille la création de nouveaux utilisateurs ou groupes ayant l'attribut adminCount défini à 1 au cours du dernier mois.

- **Explication (Cause) :** L'audit identifie que 2 objets liés à des comptes privilégiés ont été créés ou réinitialisés dans le domaine lab.local au cours des 30 derniers jours. Des événements sont enregistrés le **06/01/2026** pour le compte "**Administrateur**" et le compte "**krbtgt**". Dans un environnement stable, la création ou la modification de tels comptes constitue une opération rare devant être strictement contrôlée et documentée.
- **Conséquence (Risque) :** Selon le framework **MITRE ATT&CK**, cette activité est souvent associée à une tentative de **Persistence** par un attaquant. Si ces actions n'ont pas été initiées par l'équipe d'administration légitime, elles peuvent indiquer

qu'un intrus tente de maintenir un accès au domaine en créant de nouveaux comptes à hauts privilèges ou en manipulant des comptes critiques comme le **krbtgt**. Ce dernier est notamment utilisé pour les attaques de type **Golden Ticket**. La détection rapide de ces changements via **MITRE D3FEND** est essentielle pour auditer la légitimité des accès au domaine.

 **SECURITY INDICATOR**
Changes to Pre-Windows 2000 Compatible Access Group membership

IOE Found 

SEVERITY

Medium

WEIGHT

5

Security Frameworks
MITRE ATT&CK

- Privilege Escalation

Description
This indicator looks for changes to the built-in group "Pre-Windows 2000 Compatible Access". This group grants read-only access to Active Directory.

Likelihood of Compromise
As part of a layered approach to security and to ensure that non-authenticated users cannot read Active Directory, it's best to ensure this group does not contain the "Anonymous Logon" or "Everyone" groups.

References
[Understanding the Risks of Pre-Windows 2000 Compatible Access Settings | Semparis blog](#)

Result
Found 1 objects in the Pre-Windows 2000 Compatible Access group.

DistinguishedName	Member	Operation	EventTimestamp	Ignored
CN=Accès compatible pré-Windows 2000,CN=Builtin,DC=lab,DC=local	AUTORITE NT\Utilisateurs authentifiés	Added	06/01/2026 16:15:58	False

Showing 1 of 1

Remediation Steps
Confirm that any addition or removals from Pre-Windows 2000 Compatible Access group are valid and properly accounted for.

Changes to Pre-Windows 2000 Compatible Access Group membership (Sévérité Moyenne)

Cet indicateur surveille les changements d'appartenance au groupe intégré "Accès compatible pré-Windows 2000", qui accorde par défaut un accès en lecture à divers objets de l'Active Directory.

- **Explication (Cause)** : L'audit détecte l'ajout d'un objet dans ce groupe au sein du domaine lab.local. Le **06/01/2026 à 16:15:58**, le groupe "**Utilisateurs authentifiés**" (Authenticated Users) a été ajouté comme membre. Ce groupe historique est souvent utilisé pour maintenir la compatibilité avec d'anciens systèmes, mais l'utilisation doit être strictement limitée dans un environnement moderne car il offre une visibilité trop large sur l'annuaire à des comptes n'en ayant pas nécessairement besoin.
- **Conséquence (Risque)** : Selon le framework **MITRE ATT&CK**, cette configuration facilite l'escalade de privilèges (**Privilege Escalation**). En permettant à tous les utilisateurs authentifiés de lire les attributs de l'Active Directory, un attaquant ayant compromis un compte standard peut collecter des informations critiques sur les autres utilisateurs, les groupes et les politiques de sécurité par énumération. Pour garantir une sécurité en couches, il est crucial de s'assurer que ce groupe ne

contient pas de membres trop larges comme "**Tout le monde**" (Everyone) ou d'évaluer la nécessité réelle d'y maintenir "**Utilisateurs authentifiés**".

1

Privileged Users with Weak Password Policy

IOE Found

73%

SEVERITY

Critical

WEIGHT

8

Security Frameworks

MITRE ATT&CK

• Discovery

MITRE D3FEND

• Harden - Strong Password Policy

ANSSI

• vuln2_privileged_members_password

Description

This indicator looks for privileged users in each domain that don't have a strong password policy enforced, according to ANSSI framework. It checks both FGPP (Fine-Grained Password Policy) and the password policy applied to the domain. A strong password as defined by ANSSI is at least 8 characters long and updated no later than every 3 years.

Likelihood of Compromise

Weak passwords are easier to crack via brute-force attacks, they can provide attackers opportunities for moving laterally or escalating privileges. The risk is even higher for privileged accounts, for when easily compromised, they improve the attacker's chance to quickly advance within the network.

References

[NIST SP 800-63-3](#)

[Privileged group members with weak password policy | ANSSI](#)

Result

Found 1 privileged users who do not comply with strong password policies.

DistinguishedName	PasswordPolicyDistinguishedName	MaxAge	MinAge	MinLength	ComplexityEnabled	History
CN=Administrateur,CN=Users,DC=lab,DC=local	DC=lab,DC=local	42	1	7	True	24

Showing 1 of 1

Remediation Steps

Apply appropriate password policies for privileged users.

Privileged Users with Weak Password Policy (Sévérité Critique)

Cet indicateur identifie les utilisateurs à hauts privilèges dans chaque domaine qui ne sont pas soumis à une politique de mot de passe robuste, conformément aux recommandations de l'ANSSI.

- **Explication (Cause)** : L'audit a révélé qu'au moins un utilisateur privilégié dans le domaine lab.local ne respecte pas les critères de sécurité minimaux. Plus précisément, pour le compte "**Administrateur**", la longueur minimale du mot de passe est configurée à seulement **7 caractères** (MinLength: 7). Selon les standards de l'ANSSI et le framework NIST, un mot de passe pour un compte sensible doit comporter au moins 8 à 12 caractères et être renouvelé régulièrement pour garantir sa robustesse.
- **Conséquence (Risque)** : Selon le framework **MITRE ATT&CK**, cette faiblesse facilite grandement la phase de **Discovery** et l'escalade de privilèges. Des mots de passe courts sont vulnérables aux attaques par force brute ou par dictionnaire. Si un compte privilégié est compromis à cause d'un mot de passe trop simple, l'attaquant obtient immédiatement un contrôle étendu sur le réseau, lui permettant de se déplacer latéralement (**Lateral Movement**) ou de paralyser l'infrastructure. La mise en place d'une politique de mot de passe forte (**Harden - Strong Password Policy**) via le framework **MITRE D3FEND** est ici une priorité absolue.



SECURITY INDICATOR

Protected Users group not in use

IOE Found

99%

SEVERITY

Info

WEIGHT

1

Security Frameworks

MITRE ATT&CK

- Credential Access

ANSSI

- vuln3_protected_users

Description

This indicator checks if privileged users are in the Protected Users security group.

Likelihood of Compromise

The Protected Users security group was introduced in Server 2012 R2 Active Directory to minimize credential exposure for privileged accounts. As a defense in depth measure privileged accounts, such as Domain Admins, should be added to the Protected Users security group. Attackers targeting privileged accounts in Active Directory will find a much higher level of friction in certain types of attempts to compromise the accounts due to the protections offered.

References

[Protected Users Security Group | Microsoft Learn](#)
[Privileged accounts outside of the Protected Users group | ANSSI](#)

Result

Found 1 privileged users that are not members of the Protected Users group.

DistinguishedName	SamAccountName	Enabled	Ignored
CN=Administrateur,CN=Users,DC=lab,DC=local	Administrateur	True	False

Showing 1 of 1

Remediation Steps

Ensure that all privileged users are members of the Protected Users group. If using a pre 2012-R2 schema, then the protected users group does not exist. This is an exposure, but the remediation is to upgrade the schema.

Protected Users group not in use (S  v  rit   Info)

Cet indicateur v  rifie si les utilisateurs disposant de hauts privil  ges sont membres du groupe de s  curit   "Protected Users".

- **Explication (Cause)** : L'audit identifie que le compte "**Administrateur**" du domaine **lab.local** n'est pas membre du groupe **Protected Users**. Ce groupe est con  u pour appliquer automatiquement des restrictions de s  curit   non configurables et hautement restrictives afin de minimiser l'exposition des identifiants. Actuellement, les comptes sensibles b  n  ficient uniquement des protections standards, ce qui les laisse expos  s    des m  canismes d'authentification anciens et moins s  curis  s.
- **Cons  quence (Risque)** : Selon le framework **MITRE ATT&CK**, l'absence de ce groupe facilite l'acc  s aux identifiants (**Credential Access**). Sans les protections du groupe "**Protected Users**", les comptes privil  gi  s peuvent encore utiliser des protocoles vuln  rables comme **NTLM**, ne sont pas limit  s par des dur  es de vie de ticket **Kerberos** plus courtes et peuvent voir les identifiants mis en cache sur des h  tes compromis. L'activation de ce groupe constitue une mesure de d  fense en profondeur essentielle : elle augmente radicalement la difficult   pour un attaquant tentant de voler ou de rejouer des jetons d'authentification.

1

SECURITY INDICATOR

Users with Password Never Expires flag set

IOE Found

99%

SEVERITY

Info

WEIGHT

1

Security Frameworks

MITRE ATT&CK

- Credential Access

MITRE D3FEND

- Harden - Strong Password Policy

ANSSI

- vuln2_dont_expire

Description

This indicator identifies user accounts where the Password Never Expires flag is set. These accounts can be targets for brute force password attacks, given that their passwords may not be strong when they were set. These accounts also tend to be service accounts with privileged access to applications and services, including Kerberos-based services.

Likelihood of Compromise

Passwords that never expire may be weak and easier to crack. These credentials can provide attackers opportunities for moving laterally or escalating privileges.

References

[NIST.SP.800-63-3](#)
[Accounts with never-expiring passwords | ANSSI](#)

Result

Found 1 users with password never expires.

DistinguishedName	SamAccountName	PasswordLastSet	ServicePrincipalName	Ignored
CN=User Test,CN=Users,DC=lab,DC=local	utest	07/01/2026 09:53:49		False

Showing 1 of 1

Remediation Steps

Move any user accounts away from Password Never Expires by having a good password rotation scheme and ensure any accounts that require this flag have the least privileges required. If this is a service account, considering using Group Managed Service Accounts (gMSA).

Users with Password Never Expires flag set (S  v  rit   Info)

Cet indicateur identifie les comptes utilisateurs pour lesquels l'option "Le mot de passe n'expire jamais" est activ  e dans l'Active Directory.

- Explication (Cause) :** L'audit d  tecte un compte utilisateur (**CN=User Test,CN=Users,DC=lab,DC=local**) dont le mot de passe est d  fini pour ne jamais expirer le **07/01/2026**. Cette configuration est souvent appliqu  e par commodit   pour des comptes de service ou de test afin d'  viter des interruptions de service. Cependant, cela contrevient aux recommandations de l'ANSSI et aux standards NIST pr  conisant une rotation r  guli  re des secrets.
- Cons  quence (Risque) :** Selon le framework **MITRE ATT&CK**, cette pratique facilite l'acc  s aux identifiants (**Credential Access**). Un mot de passe sans expiration devient une cible pour les attaques par force brute sur le long terme. En cas de compromission, l'acc  s peut   tre maintenu ind  finiment, offrant des opportunit  s de d  placements lat  raux (**Lateral Movement**) ou d'escalade de privil  ges au sein du domaine lab.local.



SECURITY INDICATOR Print spooler service is enabled on a DC

IOE Found

73%
D+

SEVERITY
Critical

WEIGHT
8

Security Frameworks

MITRE ATT&CK

- Execution
- Lateral Movement
- Privilege Escalation

MITRE D3FEND

- Harden - Software Update

Description

This Indicator checks for Domain Controllers running the print spooler service.
This indicator **requires** the local server to be running the print spooler service to function, or it will return **Failed to run**.

Likelihood of Compromise

The Windows print spooler service is vulnerable to remote code execution if unpatched, commonly referred to as **PrintNightmare**. These vulnerabilities are documented in CVE-2021-34527 and CVE-2021-1675.
The print spooler service can also be used by an attacker in combination with unconstrained Kerberos delegation and TGT delegation enabled across trusts.

References

[What You Need to Know about PrintNightmare, the Critical Windows Print Spooler Vulnerability - Semparis](#)
[CVE-2021-34527 - Security Update Guide - Microsoft - Windows Print Spooler Remote Code Execution Vulnerability](#)
[CVE-2021-1675 - Security Update Guide - Microsoft - Windows Print Spooler Remote Code Execution Vulnerability](#)
[CVE-2019-0683 - Security Update Guide - Microsoft - Active Directory Elevation of Privilege Vulnerability](#)

Result

Found 1 DCs that have the Print Spooler service running.

HostName	Ignored
SRV-AD-01.lab.local	False

Showing 1 of 1

Print spooler service is enabled on a DC (Sévérité Critique)

Cet indicateur vérifie si le service Spooler d'impression (gestionnaire de travaux d'impression) est actif sur les contrôleurs de domaine.

- **Explication (Cause)** : L'audit confirme que le service **Spooler d'impression** est en cours d'exécution sur le contrôleur de domaine **SRV-AD-01.lab.local**. Par défaut, ce service est activé sur Windows Server, mais il ne possède aucune utilité légitime sur un serveur dédié à l'annuaire Active Directory. La présence sur une machine critique constitue une faille de sécurité évitable.
- **Conséquence (Risque)** : Selon les frameworks **MITRE ATT&CK** et **D3FEND**, cette configuration expose le domaine à des risques d'Exécution, de Déplacement latéral et d'Escalade de privilèges. Le Spooler est vulnérable à des failles d'exécution de code à distance, telles que **PrintNightmare** (CVE-2021-34527). Un attaquant peut exploiter ce service pour forcer le contrôleur de domaine à s'authentifier auprès d'une machine malveillante, permettant une prise de contrôle totale via des attaques par délégation Kerberos.

LDAP signing is not required on Domain Controllers

IOE Found

82%

SEVERITY

High

WEIGHT

7

Security Frameworks

MITRE ATT&CK

- Privilege Escalation
- Credential Access

Description

This indicator checks for domain controllers where LDAP signing is not required.

Likelihood of Compromise

Unsigned network traffic is exposed to MITM attacks, where attackers alter packets and forward them to the LDAP server, causing the server to make decisions based on forged requests from the LDAP client.

References

[Domain controller LDAP server signing requirements - Windows 10 | Microsoft Learn](#)
[Network security LDAP client signing requirements - Windows 10 | Microsoft Learn](#)

Result

Found 1 DCs that do not require LDAP Signing.

DistinguishedName	HostName	State	Ignored
CN=SRV-AD-01,OU=Domain Controllers,DC=lab,DC=local	SRV-AD-01.lab.local	Ldap Signing Not Required	False

Showing 1 of 1

Remediation Steps

To remediate follow the steps below:
If the steps are not followed in order, disruption to Active Directory may occur.

1. Configure clients to request LDAP signing. Group policy: **Network security\LDAP client signing requirements**, select **Negotiate signing**.
2. When all clients request signing, configure domain controllers to require LDAP signing. Group policy: **Domain Controller\LDAP server signing requirements**, select **Require signing**.
3. Configure clients to require LDAP signing. Group policy: **Network security\LDAP client signing requirements**, select **Require signing**.
4. For full details on the process please see the reference articles.

LDAP signing is not required on Domain Controllers (Sévérité Haute)

Cet indicateur vérifie si les contrôleurs de domaine (DC) exigent que les clients LDAP négocient la signature des communications.

- **Explication (Cause)** : L'audit identifie que le contrôleur de domaine **SRV-AD-01.lab.local** ne requiert pas la signature LDAP pour les échanges de données. La configuration actuelle permet des communications en clair ou non signées entre les clients et l'annuaire. Cette situation survient lorsque les politiques de sécurité par défaut n'ont pas été durcies pour imposer une intégrité des données au niveau du protocole LDAP.
- **Conséquence (Risque)** : Selon le framework **MITRE ATT&CK**, cette vulnérabilité facilite l'Escalade de privilèges et l'Accès aux identifiants. Un trafic réseau non signé est exposé à des attaques de type **Man-in-the-Middle** (MiTM). Un attaquant peut intercepter, modifier et renvoyer des paquets LDAP vers le serveur, permettant le vol de jetons d'authentification ou la modification illégitime d'objets dans l'annuaire sans détection.

SECURITY INDICATOR

RC4 or DES encryption type are supported by Domain Controllers

IOE Found

88%

SEVERITY

High

WEIGHT

6

Security Frameworks

MITRE ATT&CK

- Privilege Escalation
- Credential Access

ANSSI

- vuln2_dc_crypto
- vuln3_dc_crypto
- vuln4_dc_crypto

Description

This indicator checks if RC4 or DES encryption is supported by Domain Controllers

Likelihood of Compromise

RC4 and DES are considered an insecure form of encryption, susceptible to various cryptographic attacks. Multiple vulnerabilities in the RC4 and DES algorithms allow MitM and deciphering attacks.

References

[CVE-2013-2566](#)
[CVE-2013-2566](#)
[CVE-2015-2808](#)
[DC/RODC supported encryption algorithms | ANSSI](#)

Result

Found 1 Domain Controllers that support RC4 or DES encryption

DistinguishedName	SupportedEncryptionTypes	EventTimestamp	Ignored
CN=SRV-AD-01,OU=Domain Controllers,DC=lab,DC=local	AES 128, AES 256, RC4_HMAC_MD5	06/01/2026 15:24:46	False

Showing 1 of 1

Remediation Steps

It is best practice to disable support for RC4 and DES on domain controllers. Proceed with caution, as this can cause clients that request RC4 encrypted kerberos tickets by default to fail. Disable it by adding the group policy Network security: Configure encryption types allowed for Kerberos and select only AES-128, AES-256 encryption types, to a GPO that affects the Domain Controllers container. The group policy path is Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options.

RC4 or DES encryption type are supported by Domain Controllers (S  v  rit   Haute)

Cet indicateur v  rifie si les types de chiffrement RC4 ou DES sont autoris  s pour l'authentification Kerberos sur les contr  leurs de domaine.

- Explication (Cause) :** L'audit identifie que le contr  leur de domaine **SRV-AD-01.lab.local** supporte toujours les algorithmes **RC4_HMAC_MD5** en plus des standards AES. Ces m  thodes de chiffrement sont maintenues pour assurer la compatibilit   avec d'anciens syst  mes ou applications. Le **06/01/2026**, l'infrastructure autorisait encore l'utilisation de ces protocoles non s  curis  s.
- Cons  quence (Risque) :** Selon le framework **MITRE ATT&CK**, le maintien de RC4 et DES facilite l'Escalade de privil  ges et l'Acc  s aux identifiants. Ces algorithmes sont consid  r  s comme cryptographiquement faibles et vuln  rables    des attaques de type **Man-in-the-Middle** (MiTM) et au d  chiffrement de tickets Kerberos. Un attaquant peut exploiter ces faiblesses pour mener des attaques de type "**Silver Ticket**" ou casser plus facilement les condens  s de mots de passe circulant sur le r  seau.